ООО «ЮРИТЕХ»

юридическая онлайн-платформа

ТЕХНИЧЕСКОЕ ЗАДАНИЕ

Персональные учётные записи администраторов и регистрация по приглашениям

Доработка партнёрского кабинета: отказ от общей учётной записи, личные логины и пароли, управление доступами через супер-администратора.

Версия документа	1.0 (первая редакция)
Дата	5 ноября 2026 г.
Статус	На согласовании
Заказчик	ООО «ЮРИТЕХ», ИНН 3100009570
Система	Партнёрский кабинет, finzdorovie.ru
Основание	Решение руководства о разделении административного доступа

История изменений

Версия	Дата	Автор	Изменения
1.0	05.11.2026	Команда разработки	Первая редакция: постановка задачи, требования, критерии приёмки.

Лист согласования

Роль	ФИО	Подпись	Дата
Заказчик (руководство)			
Ответственный за продукт			
Технический руководитель			

Как читать документ

Разделы 1–5 фиксируют задачу и границы работ. Разделы 6–11 — что именно нужно сделать и как это должно быть устроено. Разделы 12–14 — как принять результат и внедрить. Раздел 16 содержит вопросы, которые нужно закрыть до старта разработки.

Содержание

1. Общие сведения
2. Назначение и цели
3. Текущее состояние
4. Границы работ
5. Роли и права
6. Функциональные требования
7. Требования к интерфейсу
8. Требования к API
9. Требования к данным
10. Требования к безопасности
11. Нефункциональные требования
12. Критерии приёмки
13. Тестирование
14. Порядок внедрения и миграция
15. Риски и меры
16. Открытые вопросы
17. Приложения

1. Общие сведения

1.1. Наименование работы

Доработка партнёрского кабинета: персональные учётные записи администраторов и регистрация по приглашениям.

1.2. Заказчик и исполнитель

Сторона	Описание
Заказчик	ООО «ЮРИТЕХ», ИНН 3100009570, г. Старый Оскол
Исполнитель	Команда разработки партнёрского кабинета (внутренняя или подрядная)
Владелец продукта	Руководство ООО «ЮРИТЕХ»
Система	Партнёрский кабинет: frontend (React + Vite), backend (FastAPI), PostgreSQL

1.3. Основание для выполнения работ

Сейчас все администраторы работают под одной общей учётной записью. Из-за этого система не различает сотрудников: в журналах и истории действий невозможно определить, кто именно выполнил операцию, а при увольнении одного человека пароль приходится менять всей команде.

Принято решение перейти на персональные учётные записи: у каждого администратора — своя почта, свой логин и свой пароль. Доступ выдаётся только по приглашению, которое создаёт супер-администратор.

1.4. Термины и сокращения

Термин	Определение
Кабинет	Партнёрский кабинет ЮРИТЕХ — веб-приложение для работы с партнёрами и клиентами.
Учётная запись	Набор данных для входа: почта, логин, пароль, роль, статус.
Общая учётная запись	Единый логин и пароль, под которым сейчас работают все администраторы.
Супер-админ	Администратор с правом управлять доступами: приглашать, блокировать, менять роли.
Админ	Сотрудник, который работает в кабинете, но не управляет доступами других.
Приглашение	Одноразовая ссылка, привязанная к конкретной почте, по которой создаётся аккаунт.
Токен приглашения	Случайная строка в ссылке; в базе хранится только её хэш.
Bootstrap-ключ	Одноразовый ключ из консоли сервера для создания первого супер-админа.
Журнал доступа	Неизменяемый список событий: входы, приглашения, блокировки, смены ролей.
Сессия	Пара токенов доступа и обновления, выданная после успешного входа.
MVP	Минимально достаточный объём доработки, описанный в разделах 6–9.

2. Назначение и цели

2.1. Цель доработки

Сделать так, чтобы каждый администратор входил в кабинет только под своими данными, а доступ выдавался осознанно — по приглашению супер-администратора.

2.2. Задачи

1. Отказаться от общей учётной записи администратора и перевести всех на личные аккаунты.
2. Ввести роль супер-администратора, который управляет доступами.
3. Реализовать приглашения: почта, роль, срок действия, одноразовая ссылка.
4. Реализовать регистрацию по приглашению: человек сам задаёт логин и пароль.
5. Ввести журнал доступа, где видно, кто и когда входил и что менял.
6. Провести миграцию: отключить общий логин, пригласить всех действующих администраторов.

2.3. Ожидаемый эффект

- Персональная ответственность: у каждого действия есть автор.
- Точечное управление доступом: выдать или забрать доступ одному человеку, не затрагивая остальных.
- Быстрое отключение при увольнении или переводе сотрудника.
- Прозрачная история входов — основа для разбора инцидентов.
- Снижение рисков, связанных с обезличенным доступом к финансовым и клиентским данным.

3. Текущее состояние

3.1. Как работает сейчас

В системе есть роль «администратор», но фактически все сотрудники используют один и тот же логин и пароль. Разделения по людям нет: система видит одного и того же пользователя, кто бы ни сел за компьютер.

3.2. Проблемы текущей схемы

Проблема	Последствие
Все действия обезличены	В истории невозможно понять, кто изменил данные или совершил операцию.
Один пароль на всех	Пароль знают все; утечка или увольнение требуют смены пароля всей команде.
Нет учёта входов	Нельзя увидеть, кто и когда заходил, в том числе в нерабочее время.
Нет точечного отзыва	Заблокировать одного сотрудника, не затронув остальных, невозможно.
Нет подтверждения личности	Почта сотрудника не связана с аккаунтом, восстановление доступа затруднено.

3.3. Вывод

Схема с общей учётной записью не масштабируется и не даёт управляемости. Требуется доработка с разделением учётных записей и управлением доступами через супер-администратора.

4. Границы работ

4.1. Что входит в работы

- Модель данных: поля логина и служебных отметок в учётной записи, таблицы приглашений и журнала.
- Серверная часть: первичная настройка, приглашения, регистрация, вход, управление доступами, журнал.
- Клиентская часть: семь экранов, описанных в разделе 7, и пункт меню «Админы» для супер-админа.
- Почтовые уведомления: приглашение и сброс пароля (при настроенном SMTP).
- Миграция: отключение общей учётной записи и приглашение действующих администраторов.
- Документация: инструкция для супер-админа и порядок восстановления доступа.

4.2. Что не входит в работы

- Двухфакторная аутентификация (2FA). Рекомендуется отдельным этапом после запуска.
- Единый вход через внешние провайдеры (SSO, Active Directory, Яндекс 360 ID).
- Изменение прав и сценариев входа партнёров — их процесс остаётся прежним.
- Регистрация администраторов без приглашения «self-signup» — не реализуется принципиально.
- Ребрендинг или редизайн кабинета: новые экраны выполняются в текущей визуальной системе.
- Мобильное приложение и push-уведомления.

5. Роли и права

5.1. Роли

Роль	Код	Назначение
Супер-администратор	super_admin	Управляет доступами: приглашает, блокирует, меняет роли, видит журнал.
Администратор	admin	Работает в кабинете с партнёрами, клиентами, задачами, финансами и чатом.
Сотрудник	staff	Ограниченный набор разделов; без финансов, настроек и управления доступами.
Партнёр	partner	Внешний пользователь кабинета; процесс входа и регистрации не меняется.

Роль «Сотрудник» вводится как задел: её состав разделов уточняется (см. раздел 16). Если заказчик решит ограничиться двумя ролями, требования к staff из документа исключаются без влияния на остальные сценарии.

5.2. Матрица доступа

Функция	Супер-админ	Админ	Сотрудник
Дашборд	Да	Да	Да
Партнёры: просмотр и редактирование	Да	Да	Да
Клиенты: просмотр и редактирование	Да	Да	Да
Задачи	Да	Да	Да
Транзакции и финансы	Да	Да	Нет
Чат и документы из чата	Да	Да	Да
Новости	Да	Да	Нет
Настройки	Да	Да	Нет
Раздел «Админы» и управление доступами	Да	Нет	Нет
Журнал доступа	Да	Нет	Нет
Приглашение и блокировка администраторов	Да	Нет	Нет
Сброс пароля другому администратору	Да	Нет	Нет

6. Функциональные требования

Требования пронумерованы. Каждый номер используется в критериях приёмки (раздел 12) и в тестах (раздел 13).

6.1. Первичная настройка и супер-администратор

FR-01 Пока в системе нет ни одного супер-администратора, единственным доступным сценарием остаётся первичная настройка по адресу /setup.

FR-02 Bootstrap-ключ создаётся серверной командой, выводится в консоль один раз, действует 60 минут и хранится в базе только в виде хэша.

FR-03 По ключу создаётся супер-администратор: почта, логин, пароль. Ключ погашается, событие фиксируется в журнале.

FR-04 После создания первого супер-администратора страница /setup возвращает 404, а повторное использование ключа отклоняется.

6.2. Приглашения

FR-05 Создавать, отзывать и перевыпускать приглашения может только супер-администратор.

FR-06 Приглашение содержит: почту, роль, срок действия (24, 72 или 168 часов; по умолчанию 72).

FR-07 Почта проверяется на формат. Приглашение на почту, уже занятую активной учётной записью, запрещено.

FR-08 Одновременно на одну почту может действовать только одно приглашение: новое отзывает предыдущее.

FR-09 Токен приглашения — случайная строка не менее 256 бит. В базе хранится только хэш токена; сравнение выполняется за постоянное время.

FR-10 Ссылка имеет вид https://<домен>/invite/<токен>. Супер-админ всегда может скопировать её из интерфейса, независимо от доставки письма.

FR-11 Если почтовый сервер настроен, приглашение отправляется письмом. Ошибка отправки не отменяет приглашение: ссылка остаётся доступной, а супер-админ видит предупреждение.

FR-12 Список приглашений показывает почту, роль, автора, дату создания, срок и статус.

FR-13 Отзыв приглашения делает ссылку недействительной немедленно.

FR-14 Перевыпуск создаёт новый токен, отзывает прежний и продлевает срок.

Статусы приглашения

Статус	Когда возникает	Что видит приглашённый	Действия супер-админа
Активно	Создано, срок не истёк, не использовано	Форму регистрации	Отозвать, перевыпустить
Использовано	Регистрация завершена	«Ссылка уже использована»	Только просмотр аккаунта
Просрочено	Истёк срок действия	«Срок действия ссылки истёк»	Перевыпустить
Отозвано	Отозвано вручную	«Приглашение отозвано»	Создать новое

6.3. Регистрация по приглашению

FR-15 Страница /invite/<токен> доступна без авторизации.

FR-16 При валидном токене отображается форма: почта (только чтение), логин, пароль, повтор пароля.

FR-17 При недействительном токене показывается причина: использован, просрочен, отозван, не найден — и инструкция, что делать дальше.

FR-18 Логин: 3–32 символа, латинские буквы, цифры, точка, дефис, подчёркивание. Уникален без учёта регистра; занятый логин отклоняется с понятной ошибкой.

FR-19 Пароль: не менее 10 символов, содержит буквы и цифры. Хранится в виде bcrypt-хэша (как и остальные пароли системы).

FR-20 При успехе создаётся учётная запись с ролью из приглашения, почта считается подтверждённой, приглашение переходит в статус «Использовано», выполняется вход в кабинет, пишется событие.

FR-21 Повторная отправка формы и двойной клик не создают вторую учётную запись.

6.4. Вход и восстановление пароля

FR-22 Вход выполняется по почте или логину и паролю.

FR-23 При ошибке выводится нейтральное сообщение «Неверный email/логин или пароль» — без указания, что именно неверно.

FR-24 Ограничение попыток: 5 неудач за 15 минут на пару «учётная запись + IP» — временная блокировка входа на 15 минут. После 3 неудач запрашивается капча.

FR-25 Успешный вход обновляет время последнего входа и фиксируется в журнале.

FR-26 «Забыли пароль» отправляет письмо со ссылкой на сброс (действует 60 минут, одноразовая). Ответ одинаков независимо от того, существует ли почта.

FR-27 Сброс пароля завершает все активные сессии пользователя.

6.5. Управление администраторами

FR-28 Список администраторов с поиском по почте и логину, фильтром по роли и статусу.

FR-29 Доступные действия: изменить роль, заблокировать, разблокировать, сбросить пароль, отозвать приглашение, скопировать ссылку приглашения.

FR-30 Блокировка, смена роли и удаление немедленно завершают активные сессии пользователя.

FR-31 Удаление реализуется как деактивация: запись сохраняется для истории и журнала. Жёсткое удаление не предусмотрено.

FR-32 Нельзя заблокировать, понизить в роли или удалить самого себя.

FR-33 Система не позволяет остаться без активного супер-администратора.

6.6. Защита от потери доступа

FR-34 Если в системе один супер-администратор, интерфейс показывает предупреждение и предлагает назначить второго.

FR-35 Восстановление доступа при утрате всех супер-админов выполняется серверной командой; порядок описан в инструкции администратора.

6.7. Журнал доступа

FR-36 Журнал фиксирует события: первичная настройка, создание/отзыв/перевыпуск приглашения, регистрация по приглашению, вход (успешный и неуспешный), выход, сброс пароля, смена роли, блокировка, разблокировка, деактивация, попытка запрещённого действия.

FR-37 Запись содержит: время (МСК), кто (учётная запись или «система»), действие, объект, результат, IP-адрес, user-agent.

FR-38 Журнал доступен только супер-администраторам. Записи нельзя редактировать или удалять.

FR-39 Хранение — 12 месяцев. Фильтры: период, тип действия, почта или логин; постраничный вывод.

6.8. Почтовые уведомления

FR-40 Письмо-приглашение содержит: кто пригласил, роль, срок действия ссылки и кнопку перехода.

FR-41 Письмо для сброса пароля содержит ссылку и срок её действия.

FR-42 Пароли в письмах не отправляются никогда.

FR-43 При недоступности почтового сервера ссылки выдаются в интерфейсе (резервный способ).

6.9. Миграция с общей учётной записи

FR-44 Общая учётная запись отключается (is_active = false) и помечается как устаревшая; запись сохраняется, чтобы история не потеряла автора.

FR-45 Приглашения для действующих администраторов создаются пакетно: вручную или импортом списка.

FR-46 Администраторы уведомляются за 5 рабочих дней; в письме — инструкция из трёх шагов.

FR-47 В течение 24 часов после переключения ответственный может временно вернуть общий доступ (флаг), если часть сотрудников не успела зарегистрироваться.

FR-48 По итогам миграции формируется отчёт: приглашено, зарегистрировано, не зашло ни разу.

7. Требования к интерфейсу

7.1. Экраны

№	Экран	Адрес	Назначение	Кому доступен
1	Вход	/login	Вход по почте или логину; без публичной регистрации	Все
2	Регистрация по приглашению	/invite/<токен>	Создание личного аккаунта	По ссылке
3	Первый запуск	/setup	Создание первого супер-админа по ключу	По ключу из консоли
4	Админы и доступы	/admin/admins	Список админов, роли, статусы, приглашения	Супер-админ
5	Приглашение (окно)	/admin/admins	Почта, роль, срок действия	Супер-админ
6	Приглашение создано (окно)	/admin/admins	Ссылка, копирование, срок	Супер-админ
7	Журнал доступа	/admin/admins → вкладка	История событий доступа	Супер-админ

7.2. Общие требования к интерфейсу

- Новые экраны выполняются в текущей визуальной системе кабинета: те же шрифты, цвета, кнопки и поля.
- На экране входа нет и не может быть кнопки «Зарегистрироваться».
- Пункт меню «Админы» отображается только супер-администратору.
- Все ошибки формулируются по-русски и объясняют, что делать дальше, без технических кодов.
- Пустые состояния содержат пояснение и действие: например, «Приглашений пока нет — пригласите админа».
- Формы проверяют поля до отправки и показывают ошибку рядом с полем.
- Интерфейс работает на экранах от 360 px; таблицы на узких экранах прокручиваются горизонтально.
- Элементы доступны с клавиатуры, у полей есть подписи, у кнопок — понятные названия.
- Пароль можно показать/скрыть; при вводе нового пароля видны требования к нему.

7.3. Макеты

Макеты всех семи экранов приведены в Приложении А. Они согласуются с заказчиком до начала разработки; отклонения от макетов допускаются только по письменному согласованию.

8. Требования к API

Пути приведены ориентировочно, в стиле существующего API. Точные имена согласуются при реализации; поведение и коды ошибок обязательны.

Метод	Путь	Назначение	Доступ
POST	/api/setup/bootstrap	Создание первого супер-админа по ключу	По bootstrap-ключу
POST	/api/auth/login	Вход по почте или логину	Без авторизации
POST	/api/auth/logout	Завершение сессии	Авторизован
POST	/api/auth/register-by-invite	Регистрация по токену приглашения	По токену
POST	/api/auth/forgot-password	Запрос ссылки на сброс пароля	Без авторизации
POST	/api/auth/reset-password	Установка нового пароля по токену	По токену
GET	/api/admin/invites	Список приглашений	Супер-админ
POST	/api/admin/invites	Создание приглашения	Супер-админ
POST	/api/admin/invites/{id}/resend	Перевыпуск приглашения	Супер-админ
DELETE	/api/admin/invites/{id}	Отзыв приглашения	Супер-админ
GET	/api/admin/users	Список администраторов	Супер-админ
PATCH	/api/admin/users/{id}	Смена роли, блокировка, разблокировка	Супер-админ
POST	/api/admin/users/{id}/reset-password	Ссылка на сброс пароля	Супер-админ
GET	/api/admin/audit	Журнал доступа с фильтрами	Супер-админ

8.2. Общие требования к API

- Все ответы — JSON; ошибки содержат машинный код и понятное человеку сообщение.
- Коды ошибок: INVITE_INVALID, INVITE_EXPIRED, INVITE_USED, INVITE_REVOKED, EMAIL_TAKEN, LOGIN_TAKEN, LAST_SUPER_ADMIN, SELF_ACTION_FORBIDDEN, RATE_LIMITED, WEAK_PASSWORD.
- Создание приглашения идемпотентно по почте: повторный запрос отзывает предыдущее приглашение.
- Списки поддерживают пагинацию и фильтры; журнал — фильтр по периоду и типу действия.
- Все действия, изменяющие доступы, пишут событие в журнал в той же транзакции.

9. Требования к данным

9.1. Учётная запись (users)

Поле	Тип	Обязательно	Комментарий
id	uuid	Да	Первичный ключ
email	varchar(255), уникальный	Да	Без учёта регистра
login	varchar(32), уникальный	Да	Новое поле; латиница, цифры, . _ -
hashed_password	varchar(255)	Да	bcrypt
role	varchar(20)	Да	partner | admin | super_admin | staff
is_active	boolean	Да	Блокировка без удаления
is_legacy_shared	boolean	Да	Признак бывшей общей учётной записи
created_by	uuid, nullable	Нет	Кто пригласил
last_login_at	timestamptz, nullable	Нет	Время последнего входа
password_changed_at	timestamptz, nullable	Нет	Для политики паролей
created_at / updated_at	timestamptz	Да	Служебные

9.2. Приглашения (invites)

Поле	Тип	Комментарий
id	uuid	Первичный ключ
email	varchar(255)	Привязана к приглашению
role	varchar(20)	Роль будущего аккаунта
token_hash	char(64), уникальный	SHA-256 от токена; сам токен не хранится
expires_at	timestamptz	Срок действия
used_at / revoked_at	timestamptz, nullable	Погашение
created_by	uuid	Автор приглашения
created_at	timestamptz	Дата создания

9.3. Журнал (audit_events)

Поле	Тип	Комментарий
id	bigserial	Первичный ключ
occurred_at	timestamptz	Время события
actor_id	uuid, nullable	Кто; null для системы
actor_label	text	Почта или логин на момент события
action	varchar(64)	Тип действия
target_type / target_id	varchar(32) / uuid	Над чем выполнено
target_label	text	Почта, логин или название объекта
result	varchar(16)	success | failure
ip	inet	Адрес клиента
user_agent	text	Браузер
meta	jsonb	Дополнительные детали без секретов

9.4. Bootstrap-ключи (bootstrap_tokens)

Таблица хранит хэш одноразового ключа, срок действия и отметку использования. Записи старше 30 дней удаляются автоматически.

9.5. Миграции

- Миграции выполняются автоматически при деплое и обратимы (up/down).
- Существующие партнёры не затрагиваются: для них поле login заполняется служебно и не используется.
- Общая учётная запись не удаляется, а деактивируется с отметкой is_legacy_shared = true.
- Перед миграцией создаётся резервная копия базы.

10. Требования к безопасности

10.1. Модель угроз и меры

Угроза	Мера защиты
Подбор пароля	Ограничение попыток, капча, блокировка на 15 минут, журналирование.
Регистрация постороннего	Публичной регистрации нет; только приглашение на конкретную почту.
Кража ссылки приглашения	Привязка к почте, одноразовость, срок 72 часа, отзыв.
Перехват сессии	HTTPS, токены с ограниченным сроком, завершение сессий при блокировке.
Утечка пароля из базы	bcrypt; пароли не логируются и не отдаются API.
Подмена автора действия	Журнал пишется на сервере, поле автора недоступно клиенту.
Захват единственного супер-админа	Минимум два супер-админа, запрет на самоблокировку.
Раскрытие существования почты	Одинаковый ответ на сброс пароля и нейтральные ошибки входа.

10.2. Дополнительные требования

- Токены приглашений и сброса пароля хранятся только в виде хэша и сравниваются за постоянное время.
- Пароль не может совпадать с логином или почтой; проверяется по списку частых паролей.
- Все административные действия доступны только по HTTPS; cookies — Secure, HttpOnly, SameSite=Lax.
- Секреты (ключ подписи, SMTP) хранятся в переменных окружения, не в репозитории.
- Персональные данные в журнале ограничены почтой и логином; содержимое клиентских документов не пишется.
- Резервное копирование базы — ежедневно; проверка восстановления — не реже раза в квартал.

11. Нефункциональные требования

Категория	Требование
Производительность	Ответ списков и приглашений — не более 300 мс на 95-м процентиле при 50 админах.
Надёжность	Ошибка отправки письма не отменяет приглашение; ссылка остаётся доступной.
Совместимость	Chrome, Safari, Firefox, Edge последних двух версий; мобильные браузеры.
Локализация	Интерфейс и письма — на русском языке; даты в московском времени.
Доступность	Контраст текста не ниже 4.5:1, работа с клавиатуры, подписи у полей.
Наблюдаемость	Ошибки входа и отправки писем попадают в логи с идентификатором запроса.
Обратная совместимость	Вход партнёров и существующие разделы кабинета работают без изменений.

12. Критерии приёмки

Работа считается выполненной, когда все сценарии ниже проходят на тестовом стенде и подтверждены на проде после миграции.

ID	Сценарий	Ожидаемый результат
A-01	Первый запуск: ввод bootstrap-ключа	Создан супер-админ, ключ погашен, /setup недоступен.
A-02	Повторный ввод того же ключа	Отказ, событие в журнале.
A-03	Создание приглашения на почту	Приглашение в статусе «Активно», ссылка копируется.
A-04	Переход по ссылке и регистрация	Аккаунт создан, выполнен вход, ссылка погашена.
A-05	Повторный переход по ссылке	Сообщение «Ссылка уже использована».
A-06	Просроченная ссылка	Сообщение об истечении срока, приглашение «Просрочено», доступен перевыпуск.
A-07	Попытка сменить почту при регистрации	Поле недоступно, подмена отклоняется сервером.
A-08	Вход по почте и по логину	Оба способа работают, журнал фиксирует вход.
A-09	Пять неудачных попыток входа	Блокировка на 15 минут, запись в журнале.
A-10	Блокировка админа супер-админом	Активная сессия завершена, вход невозможен.
A-11	Попытка заблокировать себя или последнего супер-админа	Отказ с понятной ошибкой.
A-12	Отзыв приглашения	Ссылка сразу перестаёт работать.
A-13	Прямой переход на форму регистрации без токена	Страница недоступна, публичной формы нет.
A-14	Миграция	Общий логин отключён, все действующие админы зарегистрированы.
A-15	Сброс пароля	Письмо приходит, ссылка одноразовая, сессии завершены.

13. Тестирование

13.1. Уровни тестирования

Уровень	Что проверяется
Модульные	Валидация логина и пароля, генерация и проверка токенов, расчёт срока действия.
Интеграционные	API приглашений, регистрации, входа, управления доступами, журнала.
Сквозные (E2E)	Полный путь: приглашение → регистрация → вход → блокировка → журнал.
Ручные	Письма, мобильная вёрстка, понятность ошибок, поведение при недоступной почте.

13.2. Обязательные негативные проверки

- Приглашение на занятую почту и на занятый логин.
- Просроченный, отозванный и уже использованный токен.
- Слабый пароль, пароль без цифр, пароль короче 10 символов.
- Попытка обратиться к административным методам под ролью «Админ» и «Партнёр».
- Одновременная регистрация по одной ссылке с двух устройств (второй запрос отклоняется).
- Отправка формы без сети и повторная отправка после ошибки.
- Попытка изменить роль самому себе и заблокировать последнего супер-админа.

13.3. Приёмочные данные

Тестирование проводится на копии боевой базы с обезличенными персональными данными. Почтовый сервер — тестовый ящик; дополнительно проверяется сценарий без почты (ссылка вручную).

14. Порядок внедрения и миграция

14.1. Этапы

№	Этап	Результат	Оценка
1	Согласование ТЗ и макетов	Подписанное ТЗ, утверждённые экраны	2 рабочих дня
2	Модель данных и миграции	Миграции, тестовые данные	1 день
3	Серверная часть	API приглашений, регистрации, входа, управления, журнала	5 дней
4	Клиентская часть	Семь экранов и пункт меню	5 дней
5	Почтовые шаблоны	Письма приглашения и сброса пароля	1 день
6	Тестирование	Протокол тестирования, исправленные дефекты	3 дня
7	Пилот на 2–3 админах	Подтверждение сценариев на реальных людях	2 дня
8	Миграция и коммуникация	Общий логин отключён, все приглашены	1 день

Итого — около 20 рабочих дней при одном исполнителе; при параллельной работе над серверной и клиентской частью — 3 недели. Оценка ориентировочная и уточняется после согласования.

14.2. План коммуникации

Когда	Что происходит
За 5 рабочих дней	Письмо администраторам: зачем переходим, что делать, к кому вопросы.
За 1 рабочий день	Напоминание и короткая инструкция из трёх шагов.
День переключения, 10:00	Общий логин отключается, приглашения уходят на почты.
День переключения + 1	Контроль регистраций, помощь тем, у кого не получилось.
Через 3 дня	Отчёт: кто зарегистрировался, кто нет; повторные приглашения.

14.3. Порядок отката

Если в день переключения значительная часть администраторов не может войти, ответственный включает флаг временного доступа к общей учётной записи на срок до 24 часов. Приглашения при этом остаются действительными, повторная миграция выполняется после устранения причины.

15. Риски и меры

Риск	Вероятность	Влияние	Мера
Письма попадают в спам	Средняя	Высокое	Настроить SPF/DKIM/DMARC; ссылка всегда доступна в интерфейсе.
Сотрудники не успели зарегистрироваться	Средняя	Среднее	Уведомления заранее, окно отката 24 часа, поддержка.
Утрата доступа ко всем супер-администам	Низкая	Критическое	Минимум два супер-администа, серверная процедура восстановления.
Путаница «почта или логин»	Средняя	Низкое	Подсказки на форме входа, вход по обоим идентификаторам.
Ссылка приглашения утекла	Низкая	Среднее	Привязка к почте, одноразовость, срок 72 часа.
Ошибка миграции данных	Низкая	Высокое	Резервная копия, прогон на копии базы, обратимая миграция.
Сопротивление сотрудников	Средняя	Среднее	Объяснение выгоды, простая инструкция, помощь в день X.

16. Открытые вопросы

Вопросы ниже нужно закрыть до старта разработки: от них зависят объём работ и сроки.

№	Вопрос	Варианты	Решение
1	Сколько ролей вводим?	Две (супер-администа, администа) или три (+ сотрудник)	
2	Вход по логину или только по почте?	Почта и логин / только почта	
3	Через какой сервис отправляем письма?	Яндекс 360, Mail.ru для бизнеса, SMTP-провайдер	
4	Кто второй супер-администратор?	ФИО сотрудника	
5	Дата переключения	Конкретная дата и время	
6	Нужна ли 2FA для супер-администов?	Да, отдельным этапом / нет	
7	Нужен ли экспорт журнала?	CSV / нет	
8	Срок хранения журнала	12 месяцев / иной	

17. Приложения

Приложение А. Макеты экранов

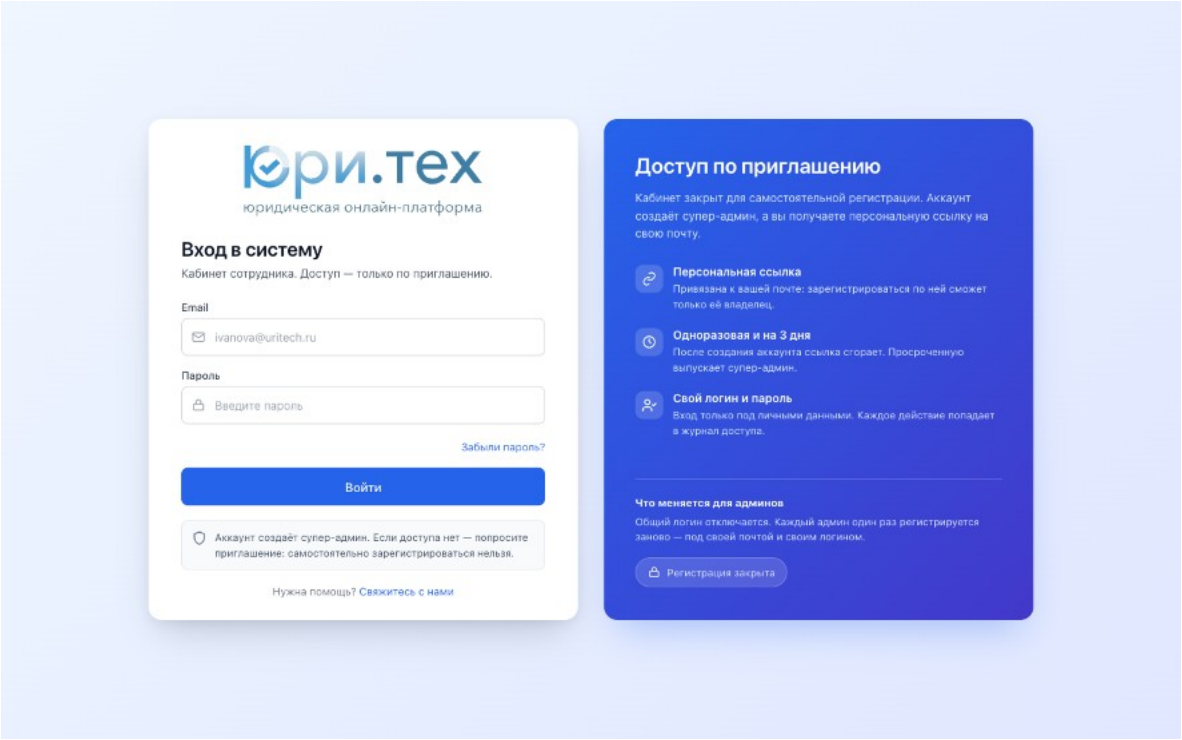


Рисунок А.1 — Экран входа: публичной регистрации нет, только вход по личным данным.

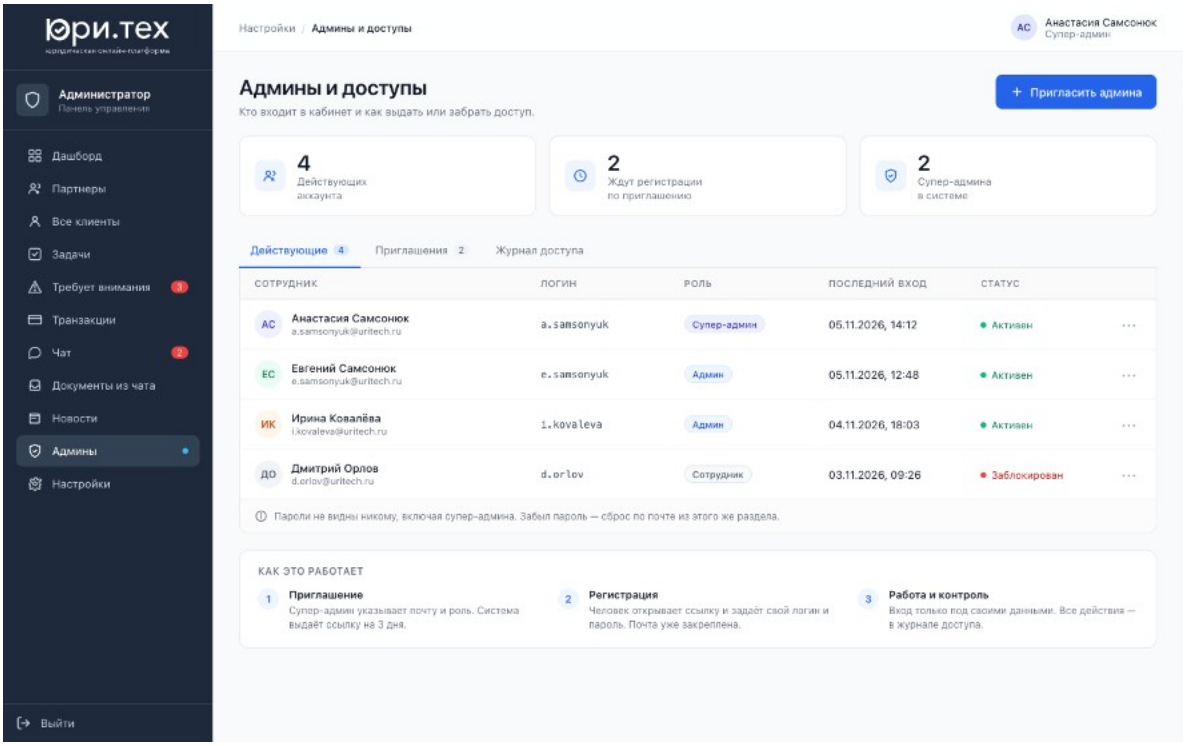


Рисунок А.2 — Раздел «Админы и доступы»: состав, роли, статусы, счётчики.

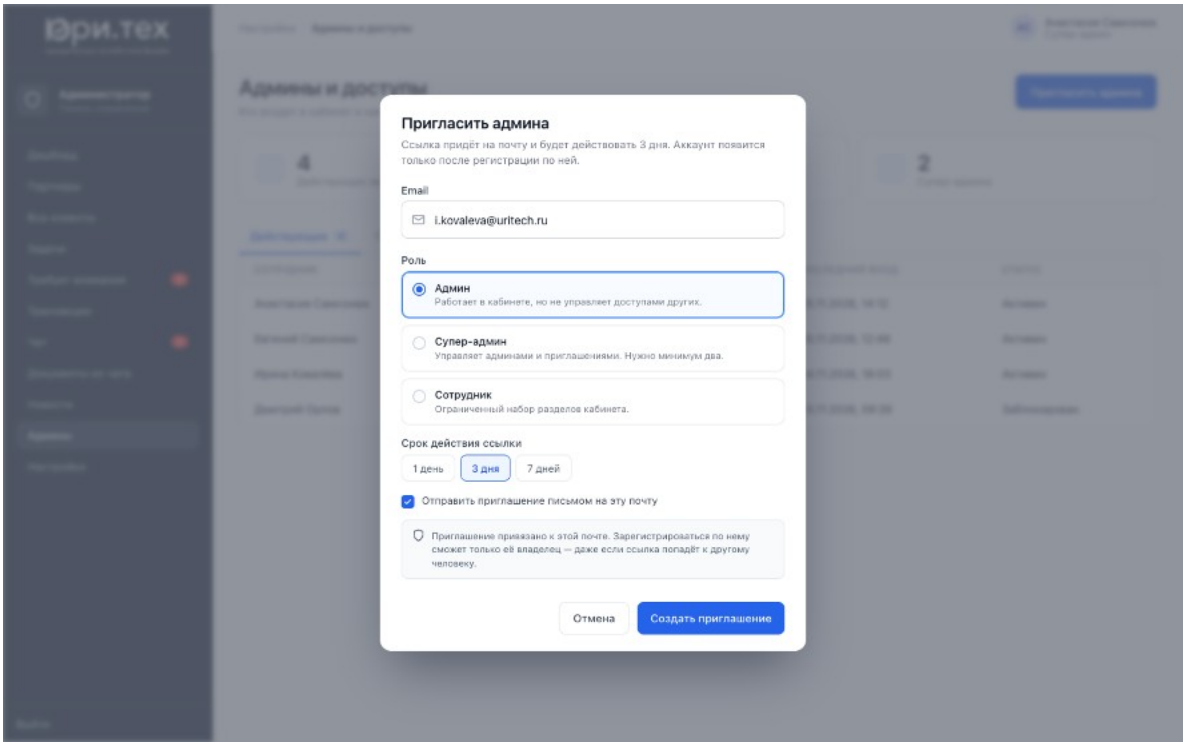


Рисунок А.3 — Создание приглашения: почта, роль, срок действия ссылки.

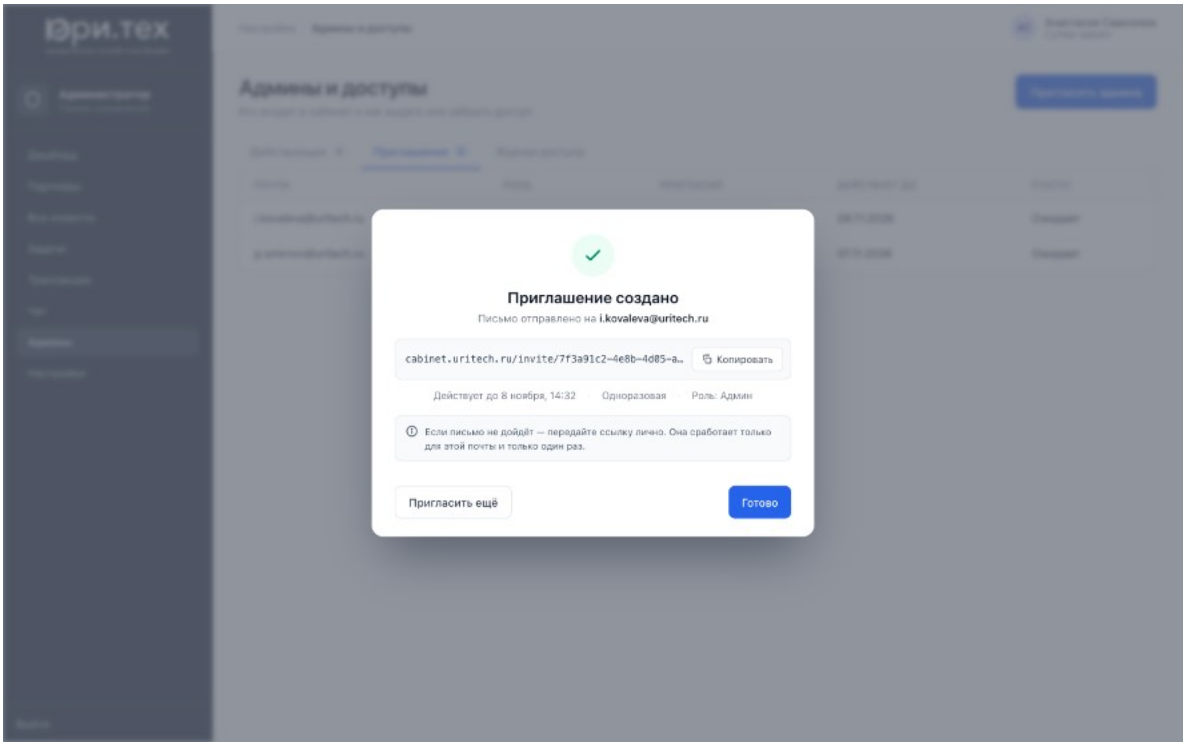


Рисунок А.4 — Приглашение создано: ссылка, срок, копирование.

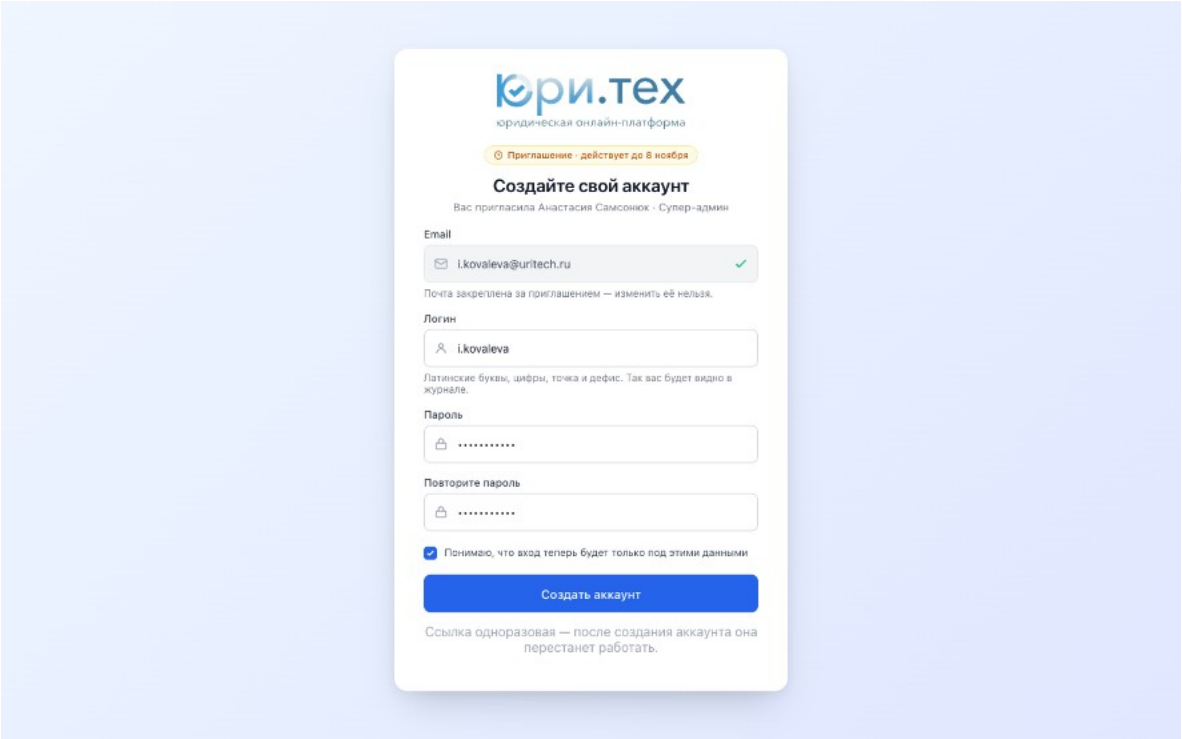


Рисунок А.5 — Регистрация по приглашению: почта закреплена, логин и пароль задаёт человек.

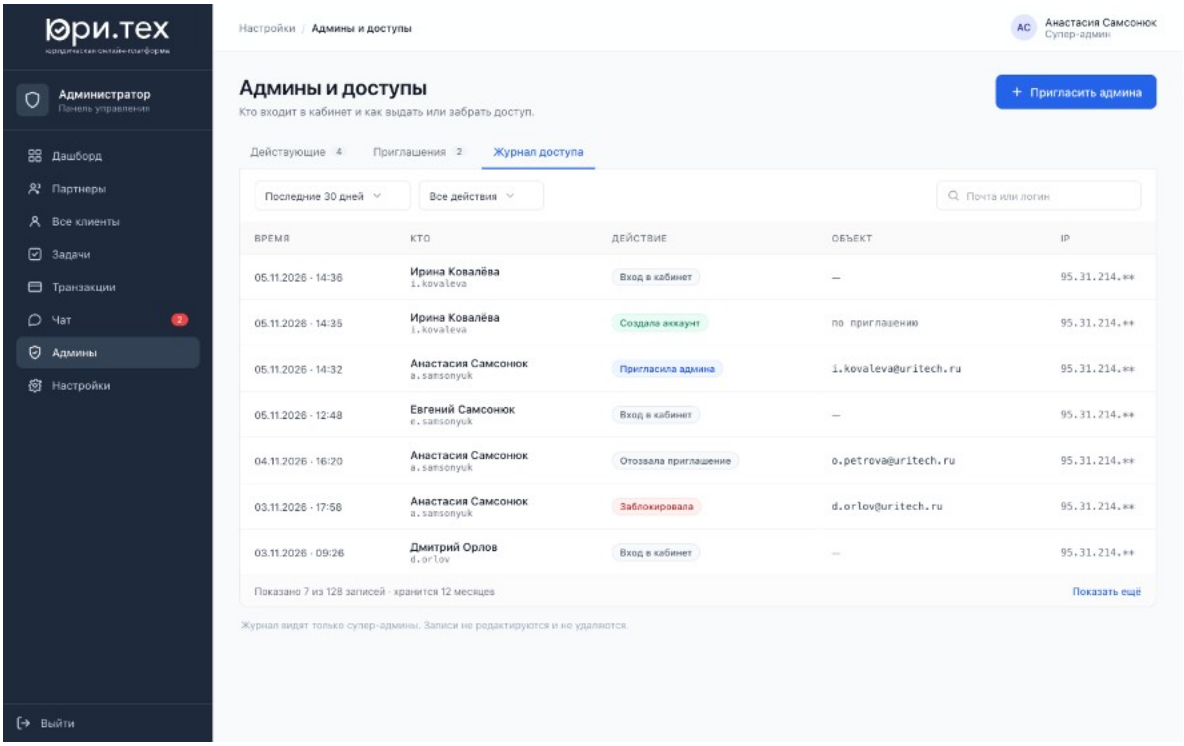


Рисунок А.6 — Журнал доступа: кто, что, когда, с какого адреса.

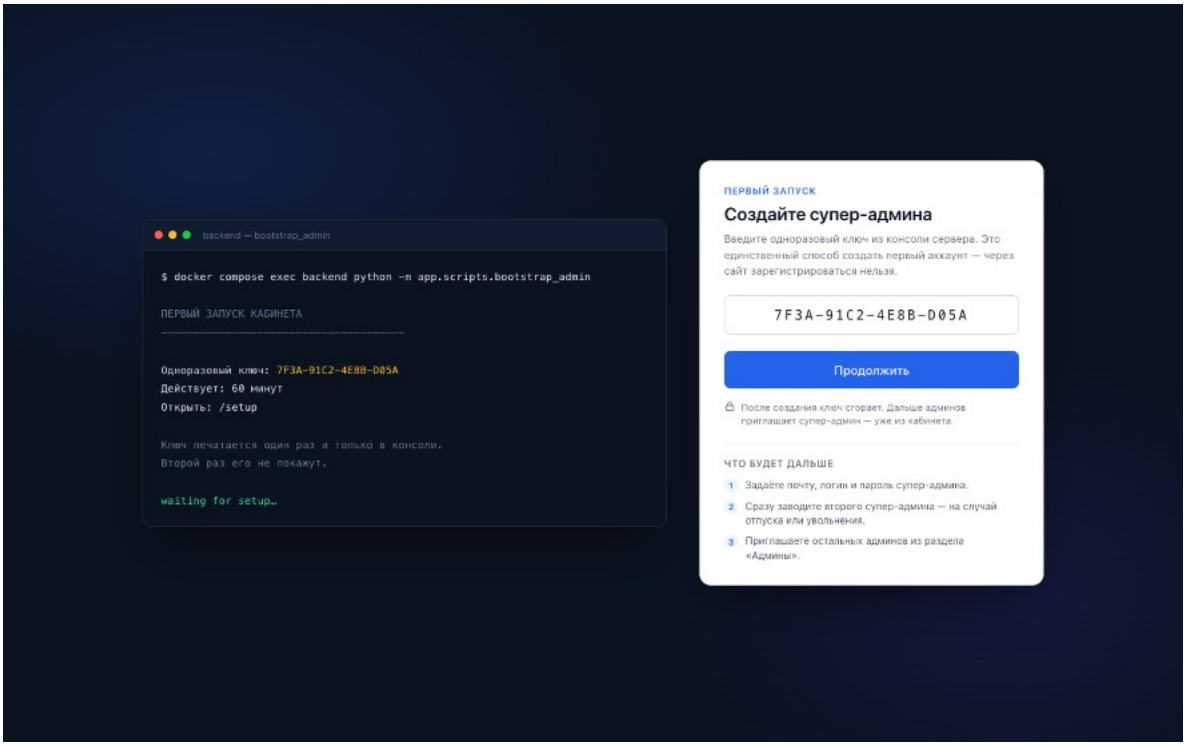


Рисунок А.7 — Первый запуск: одноразовый ключ из консоли сервера.

Приложение Б. Шаблон письма-приглашения

> **Тема письма**
>
> Доступ в кабинет ЮРИТЕХ — приглашение для {email}

Здравствуйте!

{Имя пригласившего} пригласил(а) вас в кабинет ЮРИТЕХ с ролью «{Роль}».

Чтобы создать личный аккаунт, перейдите по ссылке:

{Ссылка}

Ссылка действует до {дата и время} и может быть использована один раз. Почта {email} уже закреплена за приглашением — изменить её нельзя.

Если вы не ожидали это письмо, просто проигнорируйте его: без перехода по ссылке ничего не произойдёт.

ЮРИТЕХ · юридическая онлайн-платформа · finzdorovie.ru

Приложение В. Чек-лист супер-администратора

- Проверить, что в системе два супер-администратора.
- Пригласить всех действующих администраторов на их рабочие почты.
- Убедиться, что каждый зарегистрировался и хотя бы раз вошёл.
- Отключить общую учётную запись и убедиться, что вход под ней невозможен.
- Проверить журнал: все приглашения и регистрации видны.
- Напомнить сотрудникам, что пароль нельзя передавать коллегам.